OWASP Juice Shop Online Store: Business Requirements Document

1. Introduction

1.1 Purpose

This document describes the business requirements for the Juice Shop online store, where customers browse juices and place orders, and administrators oversee the shop.

1.2 Scope

In scope: registration, login, product catalogue, basket and checkout, account security settings and basic administration. Out of scope: mobile applications and third-party logistics integration.

2. Users and Roles

Role	Description	Access
Customer	A registered shopper	Catalogue, basket, checkout, own account settings
Administrator	Shop staff	Everything a Customer can do, plus the Administration page

3. Functional Requirements

3.1 Registration and Login

FR-1: A visitor shall be able to register a customer account by providing an email address, a password, the same password again, a security question and its answer.

FR-2: The registration form shall not be submittable until the email address is valid and both password entries match.

FR-3: A registered user shall be able to log in with their email address and password. After a successful login the user is taken to the product catalogue.

FR-4: A logged-in user shall be able to log out at any time.

Acceptance criteria for FR-1 to FR-4:

- An invalid email address is rejected with an inline message.
- Passwords that do not match are rejected with an inline message.
- Wrong credentials show an "Invalid email or password" error.

3.2 Product Catalogue

FR-5: All visitors shall be able to view the product catalogue, displayed as cards showing the product image, name and price.

FR-6: Users shall be able to search products by name or description using the search field in the top bar.

FR-7: Selecting a product card shall open a detail dialog with the full description and the customer reviews.

FR-8: A logged-in customer shall be able to add a written review to a product.

The system should respond quickly to search requests.

3.3 Basket and Checkout

FR-9: A logged-in customer shall be able to add a product to the basket, change its quantity and remove it from the basket.

FR-10: The basket page shall show each item, its quantity, the line price and the basket total.

FR-11: A customer shall be able to complete an order by choosing a delivery address, a delivery option and a payment method, then confirming the order.

FR-12: The checkout process must be user-friendly.

BR-1: A basket line quantity must be at least 1 and at most 5.

BR-2: An order cannot be placed with an empty basket.

FR-13: Customers shall earn loyalty points for every order and shall be able to redeem them at checkout.

3.4 Account and Security

FR-14: A customer shall be able to change their password by entering the current password, a new password and a repeat of the new password.

FR-15: A customer shall be able to manage saved addresses.

FR-16: A customer shall be able to request a copy of their personal data (data export) and request erasure of their account.

FR-17: A customer shall be able to configure two-factor authentication.

FR-18: Customers shall be able to choose their newsletter preferences on a dedicated preferences page.

3.5 Administration

FR-19: An administrator shall be able to open an Administration page listing all registered users and the customer feedback that was submitted.

FR-20: Administration pages are only accessible to users with the Administrator role.

4. Validation Rules

Field	Rule
Email	Required. Must be a valid email address.
Password	Required. Minimum 5 characters, maximum 40 characters.
Repeat password	Must equal the password.
Review text	Required, maximum 160 characters.
Quantity	Whole number between 1 and 5.

5. Non-Functional Requirements

NFR-1: The shop must be fast and easy to use on all supported browsers.

NFR-2: The product catalogue shall load within 3 seconds on a standard broadband connection.

NFR-3: The password strength policy is TBD and will be agreed with the security team.

NFR-4: The system shall be available 99.5% of the time during business hours.

